Informe de pruebas de seguridad — SOS Clinic

Campo	Valor
Proyecto	SOS Clinic — sistema de apoyo al triage
Tipo de evaluación	Pruebas de seguridad académicas sobre entorno local
Rama	`pruebas-seguridad-2`
Commit base	`e3f88b2` (más los commits de evidencia posteriores)
Fecha	2026-10-19
Entorno	Windows 11, Docker 29.7.2, PostgreSQL 16.15, JDK 26
Datos	Exclusivamente sintéticos; correo capturado en Mailpit
Autorización	Entorno local del repositorio, autorizado por el responsable

> **Advertencia:** este informe describe vulnerabilidades reales del prototipo. No debe usarse como guía de explotación fuera del entorno local autorizado. Los valores de tokens, contraseñas y secretos fueron omitidos o redactados.

1. Resumen ejecutivo

Se ejecutaron las fases de preparación, análisis estático, SCA, pentest manual de API, DAST con ZAP y pruebas de frontend/agente IA. Se registraron **30 hallazgos**, que tras consolidar duplicados equivalen a **25 temas únicos**:

Severidad	Cantidad
Crítica	6
Alta	8
Media	7
Baja	2
Observación	2

Riesgo global: crítico. La aplicación no autentica las APIs de pacientes y triage, no autoriza por rol las rutas administrativas y conserva un secreto JWT por defecto. En conjunto, un atacante sin credenciales puede leer y modificar datos clínicos, y cualquiera con acceso al repositorio puede emitir un token de administrador.

Hallazgos consolidados

ID	Severidad	Hallazgo	Referencias
H-01	Crítica	Secreto JWT por defecto y forja de tokens	S-01, P-01
H-02	Crítica	Lectura de pacientes y triage sin autenticación	P-03
H-03	Crítica	Escritura y altas sin autenticación	P-04
H-04	Crítica	Escalada de privilegios en `/admin/**`	P-02
H-05	Crítica	Archivo `env` con credenciales reales	S-02
H-06	Crítica	Dependencias críticas vulnerables (Tomcat/FreeMarker)	S-08, S-09
H-07	Alta	XSS almacenado en pacientes y signos vitales	P-05
H-08	Alta	Mass assignment en signos vitales	P-06
H-09	Alta	IDOR en pacientes, triage e historias PDF	P-07
H-10	Alta	Agente IA sin autenticación expone datos clínicos	P-08
H-11	Alta	CORS permisivo con credenciales	P-09
H-12	Alta	2FA sin límite de intentos	P-10
H-13	Alta	Contraseña de aplicación de Gmail en el README	S-03
H-14	Alta	Dependencias altas vulnerables (Jackson/HttpComponents)	S-10
H-15	Media	Login sin bloqueo tras intentos fallidos	P-11
H-16	Media	Envío de correo sin autenticación	P-12
H-17	Media	Enumeración de usuarios	P-13
H-18	Media	Cabeceras de seguridad ausentes	P-14, P-18
H-19	Media	Infraestructura expuesta y credenciales de desarrollo	S-05, P-19
H-20	Media	`show-sql` y secretos en logs	S-04, S-06
H-21	Media	Endpoint de voz del agente sin autenticación	P-17
H-22	Baja	Errores 500 por referencias inexistentes	P-15
H-23	Baja	Control de navegación solo en el cliente	P-20
H-24	Observación	Rol de analítica mal nombrado	P-16
H-25	Observación	Falso positivo de Power BI en gitleaks	S-07

2. Alcance y limitaciones

Incluido: gateway, seguridad, pacientes, triage, analítica, agente IA, frontend estático, PostgreSQL, pgAdmin, Eureka y Mailpit.

Excluido: `legacy/`, datos clínicos reales, producción y cualquier red externa al equipo local.

Limitaciones:

- Las pruebas se ejecutaron sobre datos sintéticos y un entorno de desarrollo.
- El frontend se sirvió con `python -m http.server`; las cabeceras del servidor definitivo pueden variar.
- ZAP se ejecutó en modo baseline (pasivo) sobre el frontend; la API se probó manualmente con scripts reproducibles.
- El análisis SCA requirió el caché local de Maven porque Maven Central respondió `429 Too Many Requests` durante la ejecución inicial.
- Trivy no detectó `docker-compose.yml`; la configuración de infraestructura se revisó manualmente.

3. Metodología

Se siguió PTES con apoyo de OWASP WSTG, OWASP API Security Top 10 2023, OWASP ASVS 4.0, ISO/IEC 27002:2022, CVSS 4.0 y STRIDE/DREAD. Cada hallazgo se reprodujo con una petición concreta y se documentó con una captura saneada.

Fase	Actividad	Resultado
0	Entorno, snapshot, usuarios de prueba	Completada
1	gitleaks, Semgrep, Trivy SCA	22 vulnerabilidades únicas
2	Pentest manual de API y autenticación	16 hallazgos
3	ZAP baseline, agente IA, infraestructura	4 hallazgos
4	Contraste con casos previos	Sin cambios relevantes
5	Informe y evidencias	Este documento

Los detalles de ejecución están en `seguridad/resultados/fase0-entorno.md`, `fase1-estatico.md`, `fase2-pentest.md` y `fase3-dast.md`.

4. Arquitectura y superficie de ataque

```
Navegador
  └── frontend :5500
        └── ms-gateway :8080
              ├── ms-seguridad :8081
              ├── ms-pacientes :8082
              ├── ms-triage :8083
              ├── ms-analitica :8084
              └── ms-ia-agente :8088
                    └── Groq API
PostgreSQL :5433 · pgAdmin :5050 · Eureka :8761 · Mailpit :8025
```

Superficie principal: APIs REST sin autenticación en pacientes y triage, rutas administrativas sin autorización por rol, gateway sin validación global de JWT, frontend que confía en `sessionStorage` y en controles de navegación del cliente, y un agente IA con acceso a datos clínicos.

5. Hallazgos críticos

H-01 — Secreto JWT por defecto y forja de tokens

Severidad: Crítica · **CWE-798, CWE-347** · **OWASP API2:2023**

`ms-seguridad` y `ms-analitica` conservan un valor por defecto para `app.jwt.secret`. Con ese valor se firma un HS256 con `perfil=administrador` y se accede a `/ms-seguridad/admin/**` y a la analítica.

- `GET /ms-seguridad/admin/personal` → **200** (2779 bytes).
- `GET /ms-seguridad/admin/perfiles` → **200**.
- `GET /ms-analitica/dashboard/resumen` → **200**.
- Firma incorrecta → **401**; token expirado → **401**; token sin `exp` → **401**.



Remediación: eliminar el fallback, exigir `APP_JWT_SECRET` desde el entorno, rotar el secreto y añadir validación de emisor/audiencia.

H-02 — Lectura de datos clínicos sin autenticación

Severidad: Crítica · **CWE-306** · **OWASP API1/API2**

`ms-pacientes` y `ms-triage` no instalan filtro de seguridad y el gateway no valida el JWT globalmente.

Endpoint sin token	HTTP	Bytes
`GET /ms-pacientes/pacientes`	200	2147
`GET /ms-pacientes/pacientes/buscar?q=0`	200	1177
`GET /ms-pacientes/pacientes/signos-vitales/registro/1`	200	2
`GET /ms-triage/triage/prioridad`	200	1802
`GET /ms-triage/triage/1`	200	429



Remediación: resource server con el mismo filtro JWT en ambos servicios y validación en el gateway.

H-03 — Escritura y altas sin autenticación

Severidad: Crítica · **CWE-306** · **OWASP API5**

Sin token se creó un paciente (id 47), un episodio (id 61) y se dio el alta con diagnóstico y tratamiento arbitrarios: `PUT /ms-triage/triage/61/atendido` → 200, estado final `Atendido`.



Remediación: autenticación obligatoria, autorización por rol y validación de transiciones de estado.

H-04 — Escalada de privilegios en rutas administrativas

Severidad: Crítica · **CWE-862** · **OWASP API5**

Un usuario `doctor_triage` creó una cuenta con `idPerfil=10` (administrador), inició sesión con ella y consultó `/admin/personal` con **200**.



Remediación: `hasRole('ADMINISTRADOR')` en `/ms-seguridad/admin/**` y separación de la gestión de usuarios.

H-05 — Credenciales reales en el archivo `env`

Severidad: Crítica · **CWE-312**

El archivo `env` (sin punto) contenía contraseña de aplicación de Gmail y clave de Groq, y no estaba en `.gitignore`. Se añadió la regla de exclusión; el archivo sigue en disco y debe moverse fuera del repositorio y rotarse.

Remediación: gestor de contraseñas, rotación de Gmail y Groq, y hook de gitleaks antes de cada commit.

H-06 — Dependencias críticas vulnerables

Severidad: Crítica · **CWE-1104** · **OWASP A06:2021**

Trivy reportó 22 vulnerabilidades únicas (4 críticas, 12 altas, 6 medias) en los siete módulos. Las críticas: tres en Tomcat 11.0.24 y una en FreeMarker 2.3.34.



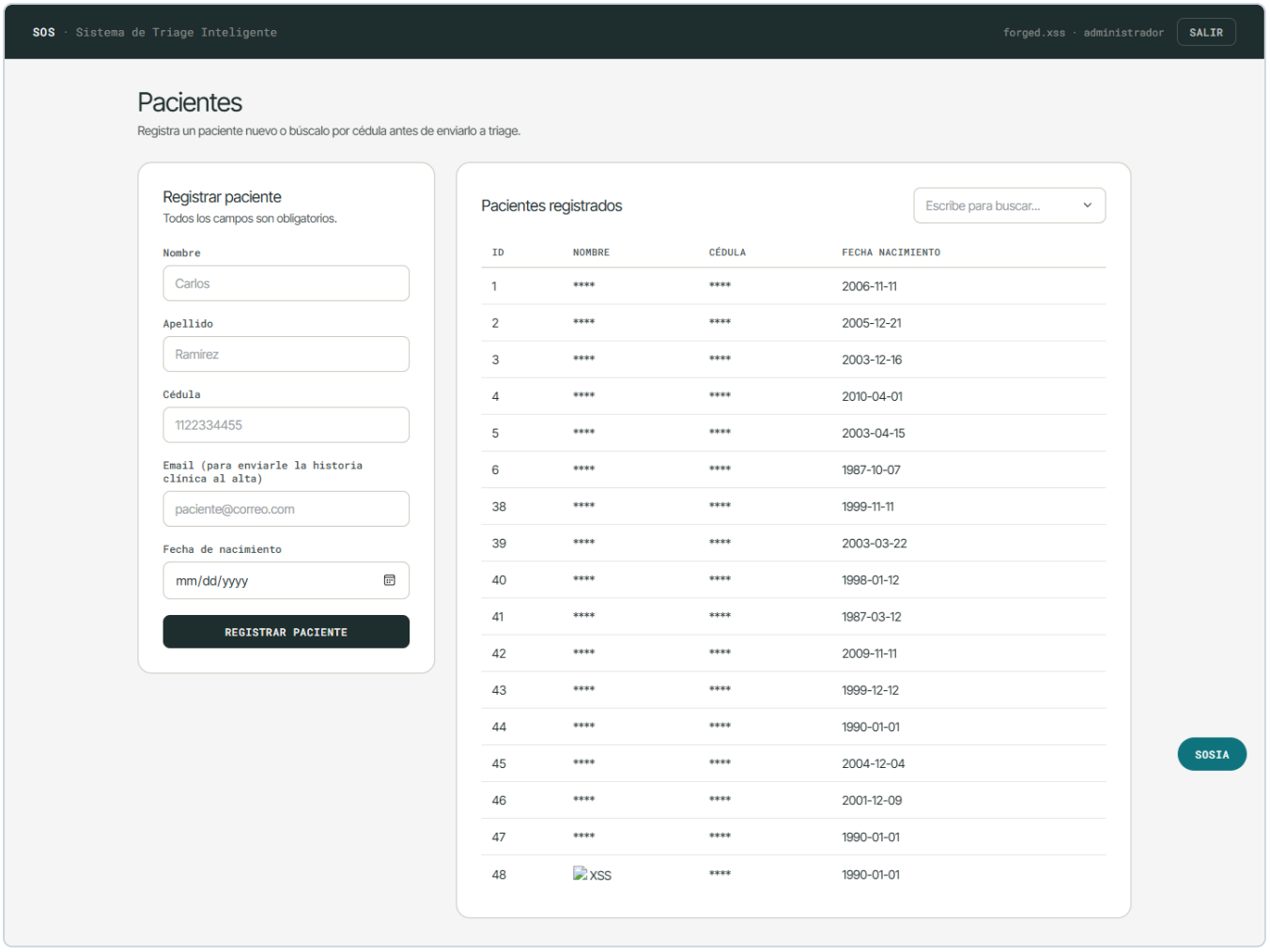
Remediación: Tomcat 11.0.25+, FreeMarker 2.3.35, Jackson y HttpComponents a las versiones corregidas; repetir el SCA.

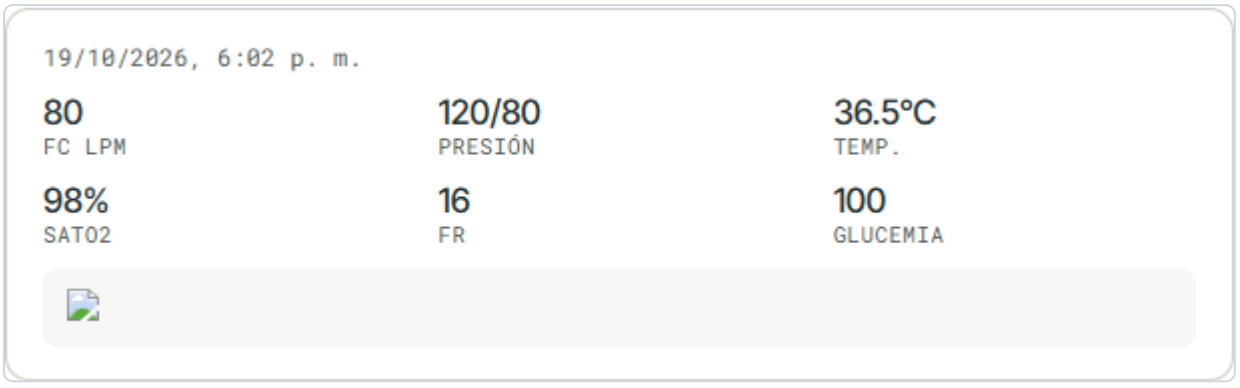
6. Hallazgos altos

H-07 — XSS almacenado

Severidad: Alta · **CWE-79** · **OWASP A03:2021**

`pacientes.html` inserta nombre y apellido con `innerHTML`; `seguimiento.html` hace lo mismo con `descripcionSintoma`. Un paciente con `<img src=x onerror=alert(1)>` ejecutó `alert("1")` en ambas páginas.





Remediación: `textContent` / `createElement`, codificación de salida y CSP.

H-08 — Mass assignment en signos vitales

Severidad: Alta · **CWE-915** · **OWASP API3:2023**

`POST /pacientes/signos-vitales` enlaza el JSON a la entidad `EstadoPaciente`. Se aceptó `idPersonal=9` (otro usuario); `idEstado` y `fechaHoraToma` fueron sobrescritos por el controlador. Un `idPersonal` inexistente produce **500**.

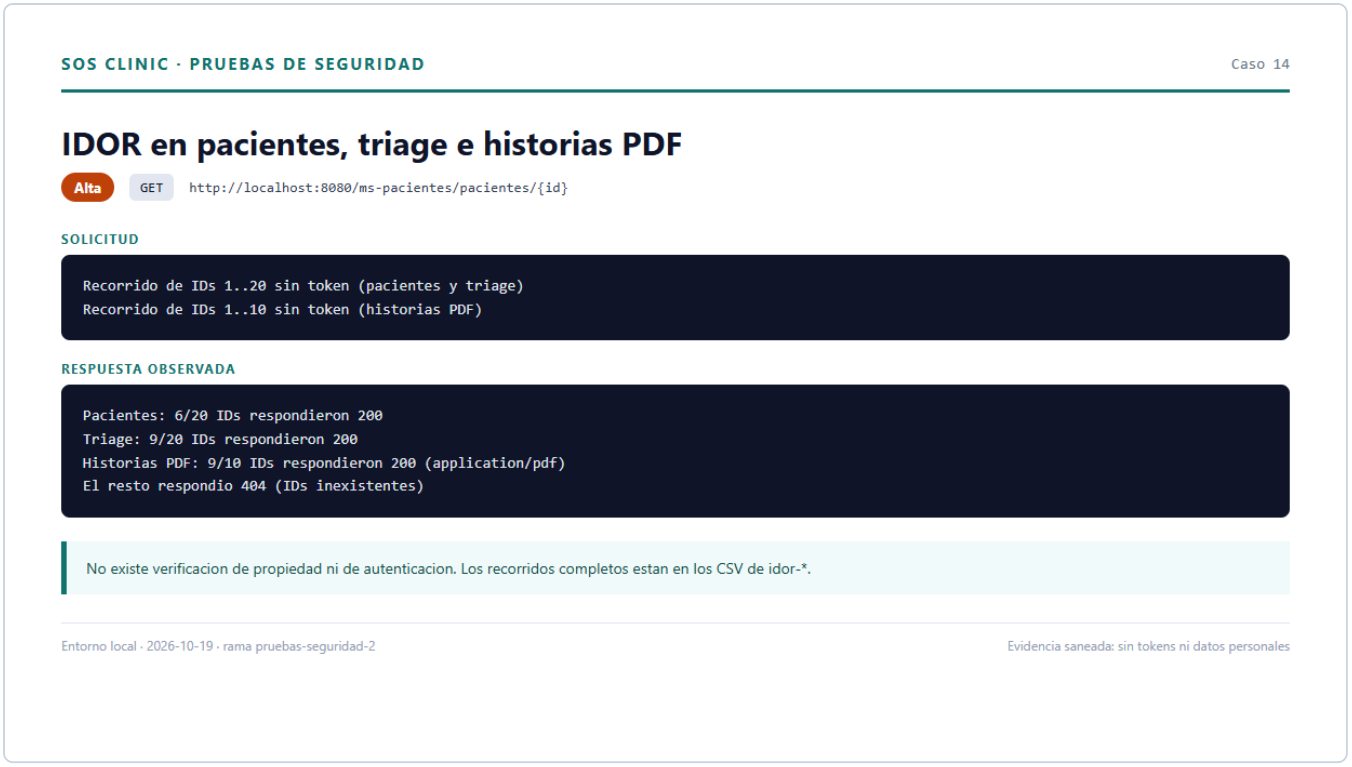


Remediación: DTO con campos permitidos y `idPersonal` obtenido del token.

H-09 — IDOR

Severidad: Alta · **CWE-639** · **OWASP API1:2023**

Sin token: 6/20 pacientes, 9/20 episodios y 9/10 historias PDF respondieron 200. No existe verificación de propiedad ni de autenticación.



H-10 — Agente IA sin autenticación

Severidad: Alta · **CWE-306** · **OWASP API2:2023**

`POST /agente/preguntar` respondió 200 sin token y devolvió el conteo de la lista de espera, la mayor espera y el nombre del primer paciente (redactado en la evidencia). Las herramientas del agente consultan pacientes y triage sin token.



Remediación: exigir JWT, limitar herramientas al usuario autenticado y aplicar rate limiting.

H-11 — CORS permisivo

Severidad: Alta · **CWE-942**

`Origin: http://evil.local` fue reflejado con `Access-Control-Allow-Credentials: true` y métodos `GET,POST,PUT,DELETE,OPTIONS`.



Remediación: lista blanca de orígenes y no habilitar credenciales sin necesidad.

H-12 — 2FA sin límite de intentos

Severidad: Alta · **CWE-307**

Diez códigos incorrectos → 401; el código correcto después → 200. No hay bloqueo ni invalidación. El código es de un solo uso (reuso → 401), pero de seis dígitos y cinco minutos.



Remediación: límite por usuario/IP, bloqueo temporal, `SecureRandom` y hash del código.

H-13 — Contraseña de aplicación de Gmail en el README

Severidad: Alta · **CWE-312**

El README incluye una contraseña de aplicación de Gmail en texto plano. Debe considerarse comprometida y rotarse; gitleaks no la detectó por su formato.



H-14 — Dependencias altas vulnerables

Severidad: Alta · **CWE-1104**

Doce CVEs altas en Jackson (2.21.5 y 3.1.5) y HttpComponents (5.3.6). El detalle está en `resultados/trivy-sca-resumen-2026-10-19.csv`.

7. Hallazgos medios y bajos

ID	Hallazgo	Evidencia	Remediación
H-15	Login sin bloqueo tras 10 fallos	—	Rate limiting y bloqueo progresivo
H-16	Envío de correo sin autenticación	`17_correo_sin_token.png`	Exigir JWT y limitar destinatarios
H-17	Enumeración por “Usuario inactivo”	`18_enumeracion_usuarios.png`	Mensaje genérico y tiempos uniformes
H-18	Cabeceras de seguridad ausentes (ZAP)	`21_zap_baseline.png`	CSP, HSTS, X-Frame-Options, etc.
H-19	Eureka, pgAdmin y PostgreSQL expuestos	—	Limitar a localhost y credenciales fuertes
H-20	`show-sql` y secretos en logs	—	Desactivar en producción y sanear logs

ID	Hallazgo	Evidencia	Remediación
H-21	Voz del agente sin autenticación	—	Exigir JWT y limitar tamaño/rate
H-22	Errores 500 por referencias inexistentes	—	Devolver 400/404 controlados
H-23	Navegación controlada solo en el cliente	—	Autorización en el backend
H-24	Rol `coordinador_turnos` ≠ `COORDINACION`	—	Unificar nombres de rol
H-25	Falso positivo de Power BI	—	Documentar y excluir en gitleaks

8. Pruebas sin hallazgo

Prueba	Resultado
Inyección SQL en `buscar?q=`	200 con arreglo vacío; sin error de SQL
Inyección SQL en `cedula/{valor}`	404
Firma JWT incorrecta	401
JWT expirado	401
JWT sin `exp`	401
Reutilización del código 2FA	401
Categoría de triage inexistente	400
Dashboards de analítica con rol incorrecto	403

La revisión de `DashboardRepository` confirma parámetros nombrados y nombres de columna fijos.

9. Matriz STRIDE/DREAD (resumen)

Componente	S	T	R	I	D	E	Riesgo
ms-seguridad	Alta	Alta	Media	Alta	Media	Alta	Crítico
ms-pacientes	Alta	Alta	Baja	Alta	Media	Media	Crítico
ms-triage	Alta	Alta	Baja	Alta	Media	Media	Crítico
ms-gateway	Media	Media	Baja	Media	Media	Alta	Alto
ms-analitica	Baja	Baja	Baja	Media	Baja	Baja	Medio
ms-ia-agente	Alta	Media	Media	Alta	Media	Alta	Alto

Componente	S	T	R	I	D	E	Riesgo
Frontend	Media	Media	Baja	Alta	Baja	Media	Alto

10. Plan de remediación priorizado

Prioridad	Acción	Hallazgos
1	Autenticar y autorizar pacientes/triage; validar JWT en el gateway	H-02, H-03, H-09, H-23
2	Restringir `/admin/**` a administradores	H-04
3	Eliminar y rotar el secreto JWT	H-01
4	Mover `env` fuera del repo y rotar Gmail/Groq	H-05, H-13
5	Actualizar Tomcat, FreeMarker, Jackson y HttpComponents	H-06, H-14
6	Rate limiting y bloqueo en login/2FA	H-12, H-15
7	Corregir XSS y mass assignment	H-07, H-08
8	Autenticar y limitar el agente IA	H-10, H-21
9	Restringir CORS y añadir cabeceras	H-11, H-18
10	Endurecer infraestructura y manejo de errores	H-19, H-20, H-22

11. Conclusiones

El prototipo prioriza la funcionalidad sobre la seguridad. La combinación de APIs sin autenticación, rutas administrativas sin autorización por rol y un secreto JWT versionado permite comprometer confidencialidad, integridad y disponibilidad de la información clínica sin credenciales. Las correcciones de las prioridades 1 a 4 son urgentes y de bajo esfuerzo; las restantes pueden planificarse como endurecimiento progresivo.

Las pruebas se hicieron sobre datos sintéticos y un entorno local. No se utilizaron datos clínicos reales ni se enviaron correos fuera de Mailpit.

12. Anexos

- Plan y metodología: `seguridad/PLAN.md`.
- Fase 0: `seguridad/resultados/fase0-entorno.md`.
- Fase 1: `seguridad/resultados/fase1-estatico.md`.
- Fase 2: `seguridad/resultados/fase2-pentest.md`.
- Fase 3: `seguridad/resultados/fase3-dast.md`.
- Evidencias: `seguridad/evidencias/`.
- Resultados crudos: `seguridad/resultados/`.
- Utilidades: `seguridad/utilidades/`.